UNIVERSITI KUALA LUMPUR

MALAYSIAN INSTITUTE OF INFORMATION TECHNOLOGY

IKB21403 VULNERABILITY ANALYSIS

BACHELOR OF INFORMATION TECHNOLOGY (HONS)

IN COMPUTER SYSTEM SECURITY

LAB WEEK 5

Active-Footprinting

PREPARED BY:

1.	**MUHAMMAD ANAS BIN MOHD RAMLEE**	**52215125186**

PREPARED FOR:

MADAM ADANI

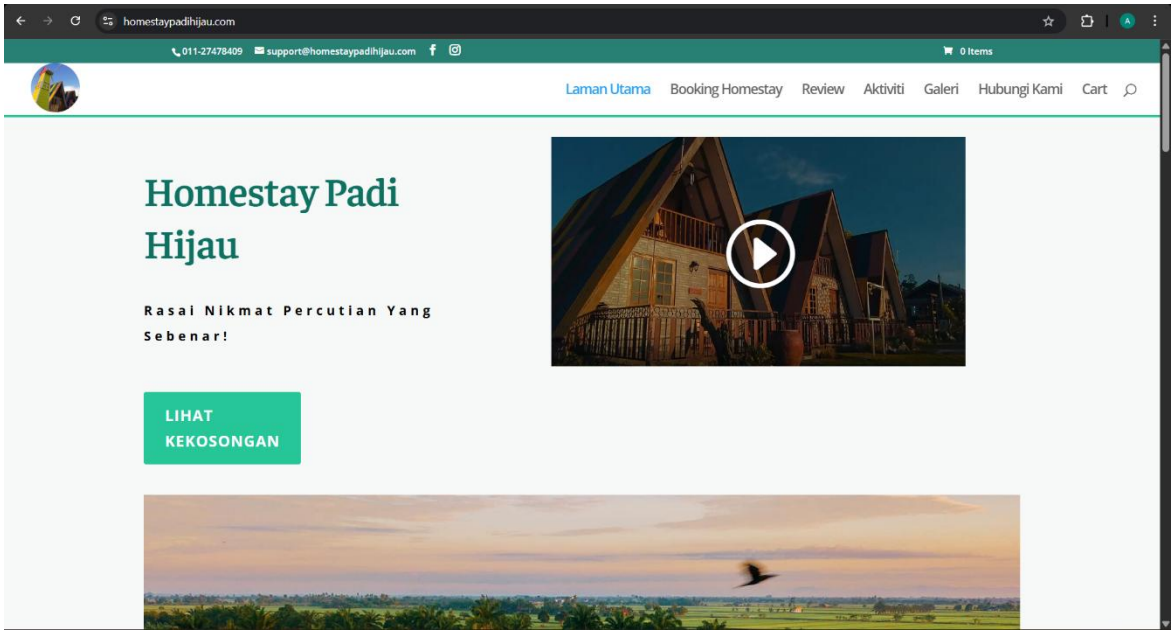
Step	Tool	Finding	Interpretation	Mitigation
WHOIS	Whois	Registered via NameSilo; Expires 2026-10-10	Shows domain ownership and lifecycle; nameservers are JIMATDNS.COM	Use domain privacy protection to hide registar details.
DNS Enumeration	Nslookup,dig	IP address resolved to 103.191.76.66	Reveals public infrastructure and server location	Restrict unnecessary DNS record to minimize info leakage
Subdomain Discovery	Pentest-Tools	11 subdomains were found	Expands attack surface by identifying management portals.	Limit exposure of unused subdomains
Tech Footprinting	BuiltWith	Site uses Tidio chat and CrUX dataset.	Identifying the technology stack and integrations.	Keep software updated and patched
Web Headers	`curl -I`	Server: LiteSpeed; Powered by PHO/7.4.33.	PHP 7.4 identified possible misconfiguration	Update PHP to a supported version (8.x)
robots.txt	Curl	Disallows /wp admin/ and WooCommerce paths	Information disclosure of internal directory structure	Avoid exposing sensitive paths; restrict access via IP.
WAF Detection	`wafw00f`	Request timed out; blocking at connection level	Indicates security solution is actively protecting the site	Implement a dedicated WAF if the current one is basic
SSL/TLS Analysis	SSL Labs	Overall Rating: A support TLS 1.3	Detects encryption strength; shows strong security posture	Enforce strong TLS(1.2/1.3)

Email security	dig … TXT	No TXT/SPF/DMARC records found in DNS	Domain is highly vulnerable to email spoofing and phishing.	Implement SPF,DKIM and DMARC records immediately

Lab Objective:

The primary objective of this lab is to perform Active Footprinting to map out the digital presence, infrastructure, and potential security weaknesses of the target website, homestaypadihijau.com/ by using various tools, you aim to identify exposed information that could be leveraged by an attacker to plan a more sophisticated exploit.

Website url: https://homestaypadihijau.com/



Domain Enumeration

1. **WHOIS**

- Think of this as looking up a person's public record in a phone book. It tells you who registered the domain and when it will expire.
- To identify the domain registrar and ownership lifecycle. This helps an attacker know when a domain might lapse or who to target for social engineering.

`whois homestaypadihijau.com`

```
┌──(kali㉿kali)-[~]
└─$ whois homestaypadihijau.com
   Domain Name: HOMESTAYPADIHIJAU.COM
   Registry Domain ID: 2646783000_DOMAIN_COM-VRSN
   Registrar WHOIS Server: whois.namesilo.com
   Registrar URL: http://www.namesilo.com
   Updated Date: 2025-09-19T07:15:08Z
   Creation Date: 2021-10-10T12:53:31Z
   Registry Expiry Date: 2026-10-10T12:53:31Z
   Registrar: NameSilo, LLC
   Registrar IANA ID: 1479
   Registrar Abuse Contact Email: abuse@namesilo.com
   Registrar Abuse Contact Phone: +1.4805240066
   Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
   Name Server: NS3.JIMATDNS.COM
   Name Server: NS4.JIMATDNS.COM
   DNSSEC: unsigned
   URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-04-15T16:56:50Z <<<
```

DNS Enumeration

- This maps the website's name to its actual physical address (IP address) on the internet.
- To reveal the public infrastructure and the specific server location (103.191.76.66). Knowing the IP allows for more direct network scanning.

1. **NSLOOKUP**

nslookup homestaypadihijau.com

```
┌──(kali㉿kali)-[~]
└─$ nslookup homestaypadihijau.com
Server:         192.168.0.1
Address:        192.168.0.1#53

Non-authoritative answer:
Name:   homestaypadihijau.com
Address: 103.191.76.66
```

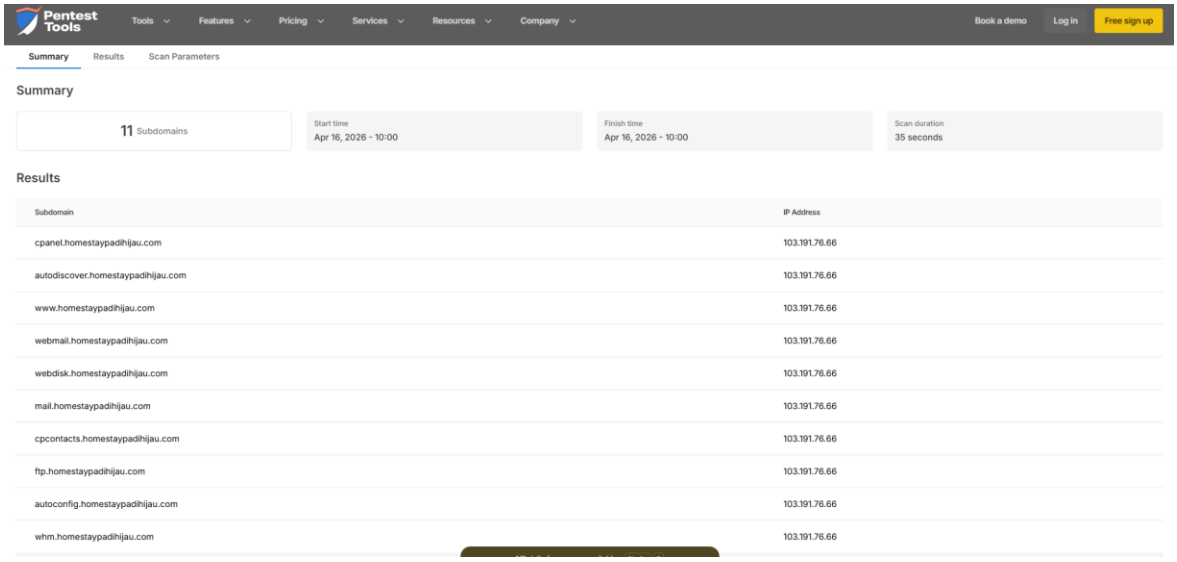
2. **DIG**

dig homestaypadihijau.com

```
┌──(kali㉿kali)-[~]
└─$ dig homestaypadihijau.com

; <<>> DiG 9.20.20-1-Debian <<>> homestaypadihijau.com
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 43863
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;homestaypadihijau.com.         IN      A

;; ANSWER SECTION:
homestaypadihijau.com.  900     IN      A       103.191.76.66

;; Query time: 20 msec
;; SERVER: 192.168.0.1#53(192.168.0.1) (UDP)
;; WHEN: Wed Apr 15 21:57:27 EDT 2026
;; MSG SIZE  rcvd: 66
```

Subdomain Discovery

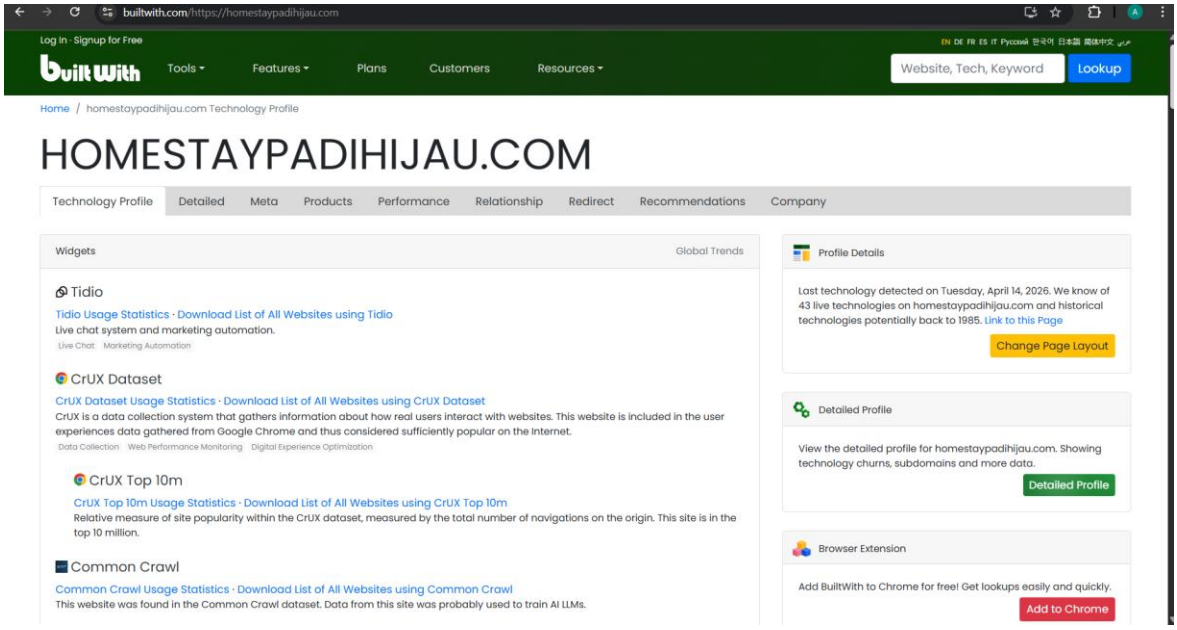
- This searches for "hidden" rooms in the house, such as cpanel, mail, or ftp.
- To expand the "attack surface".Each subdomain is a potential new target that might be less secure than the main website.



Technology Footprinting

- This identifies the "ingredients" used to build the site, like the chat widgets (Tidio) or data collection systems.
- To understand the technology stack. If a specific widget has a known bug, the attacker knows exactly what to exploit.

1. Buildwith



Web Header and Basic Info

- This reads the "labels" the server sends back when you visit.
- To identify the server software (LiteSpeed) and programming language version (PHP 7.4.33). Finding an old version like PHP 7.4 is critical because it is no longer patched against new threats.

curl -I https://homestaypadihijau.com

```
┌──(kali㉿kali)-[~]
└─$ curl -I https://homestaypadihijau.com
HTTP/2 200
x-powered-by: PHP/7.4.33
content-type: text/html; charset=UTF-8
link: <https://homestaypadihijau.com/wp-json/>; rel="https://api.w.org/"
link: <https://homestaypadihijau.com/wp-json/wp/v2/pages/8>; rel="alternate"; title="JSON"; type="application/json"
link: <https://homestaypadihijau.com/>; rel=shortlink
date: Thu, 16 Apr 2026 02:10:19 GMT
server: LiteSpeed
alt-svc: h3=":443"; ma=2592000, h3-29=":443"; ma=2592000, h3-Q050=":443"; ma=2592000, h3-Q046=":443"; ma=2592000, h3-Q043=":443"; ma=2592000, quic=":443"; ma=2592000; v="43,46"
```

curl https://homestaypadihijau.com/robots.txt

- To find hidden directory paths like /wp-admin/. By seeing what the owner wants to hide, an attacker finds exactly where the sensitive admin areas are located.

```
┌──(kali㉿kali)-[~]
└─$ curl https://homestaypadihijau.com/robots.txt
User-agent: *
Disallow: /wp-content/uploads/wc-logs/
Disallow: /wp-content/uploads/woocommerce_transient_files/
Disallow: /wp-content/uploads/woocommerce_uploads/
Disallow: /*?add-to-cart=
Disallow: /*?*add-to-cart=
Disallow: /wp-admin/
Allow: /wp-admin/admin-ajax.php

Sitemap: https://homestaypadihijau.com/sitemap.xml
Sitemap: https://homestaypadihijau.com/sitemap.rss
```

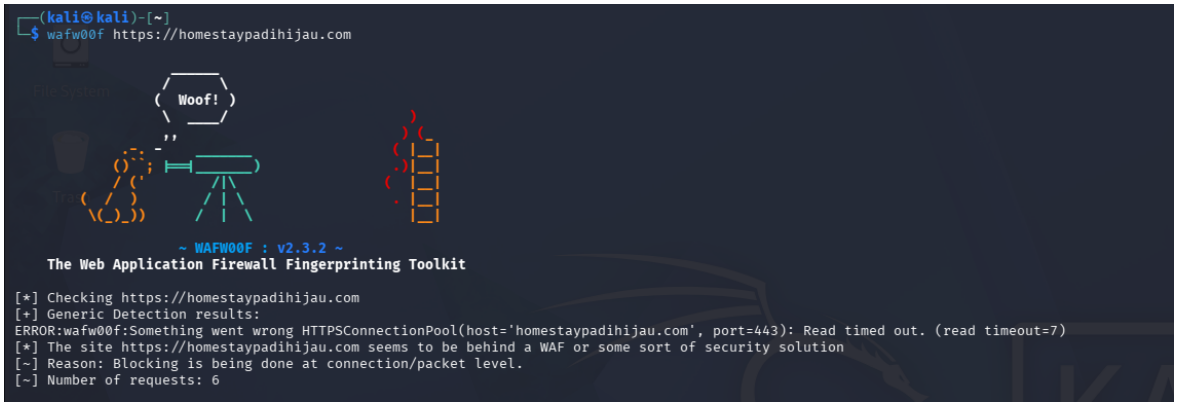
Found:

- The file explicitly instructs web crawlers to avoid sensitive directories such as /wp-admin/, /wc-logs/, and various WooCommerce upload folders.

WAF Detection

- This checks if there is a "security guard" (Firewall) standing at the door.
- To determine the level of protection.

wafw00f https://homestaypadihijau.com

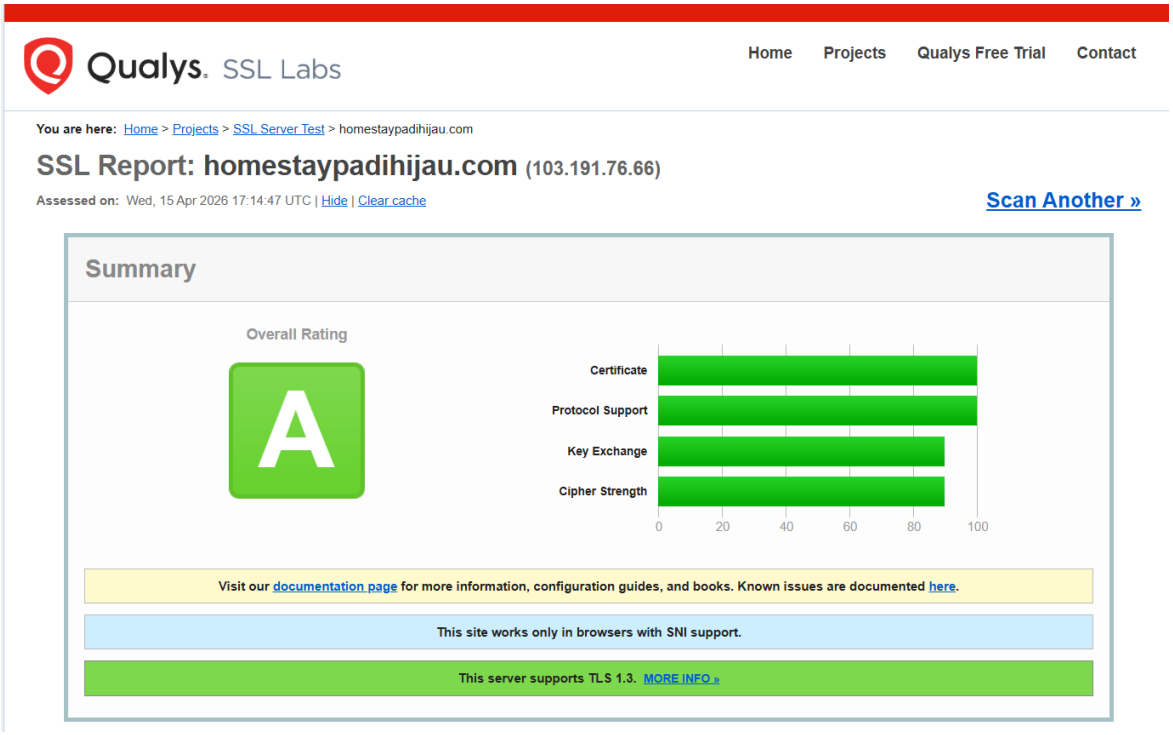


I found:

- The server is blocking the wafw00f tool at the connection or packet level.

SSL / TLS Info

- This checks the "lock" on the front door to see if the connection is encrypted and secure.
- To detect weak encryption or old protocols.



Certificate #1: RSA 2048 bits (SHA256withRSA)

Server Key and Certificate #1

Subject	homestaypadihijau.com Fingerprint SHA256: 704293ba407e55c5449f80b7edbd33a7097ff4507f56e8c0bdace5198d56e185 Pin SHA256: qVoqNE0msBZKp4kh5r19yvNFRV62kI9LV0xVHIlfV+o=
Common names	homestaypadihijau.com
Alternative names	*.homestaypadihijau.com homestaypadihijau.com
Serial Number	069a3dedb10540a4546a8a45bbb07fdadb8d
Valid from	Sun, 22 Mar 2026 11:54:13 UTC
Valid until	Sat, 20 Jun 2026 11:54:12 UTC (expires in 2 months and 4 days)
Key	RSA 2048 bits (e 65537)
Weak key (Debian)	No
Issuer	R12 AIA: http://r12.i.lencr.org/
Signature algorithm	SHA256withRSA
Extended Validation	No
Certificate Transparency	**Yes (certificate)**
OCSP Must Staple	No
Revocation information	CRL CRL: http://r12.c.lencr.org/14.crl
Revocation status	Good (not revoked)
DNS CAA	No (more info)
Trusted	**Yes** **Mozilla Apple Android Java Windows**

Configuration

Protocols

TLS 1.3	Yes
TLS 1.2	Yes*
TLS 1.1	No
TLS 1.0	No
SSL 3	No
SSL 2	No

(*) Experimental: Server negotiated using No-SNI

Cipher Suites

# TLS 1.3 (server has no preference)		
TLS_AES_128_GCM_SHA256 (0x1301)	ECDH x25519 (eq. 3072 bits RSA) FS	128
TLS_AES_256_GCM_SHA384 (0x1302)	ECDH x25519 (eq. 3072 bits RSA) FS	256
TLS_CHACHA20_POLY1305_SHA256 (0x1303)	ECDH x25519 (eq. 3072 bits RSA) FS	256
# TLS 1.2 (suites in server-preferred order)		
TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (0xc02f)	ECDH x25519 (eq. 3072 bits RSA) FS	128
TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (0xc030)	ECDH x25519 (eq. 3072 bits RSA) FS	256
TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256 (0xcca8)	ECDH x25519 (eq. 3072 bits RSA) FS	256

I found:

- My target received an A rating, meaning the connection between the user and the server is currently very strong and secure.